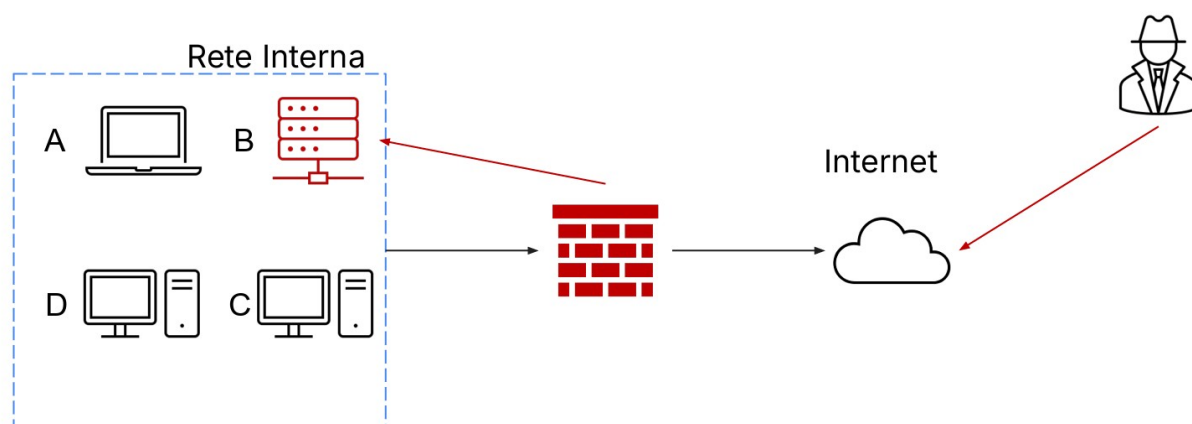


Incident Response & Malware Analysis

1 - Objective :

Analyse a real-world cybersecurity incident scenario in which System B — a database server — has been compromised by an external attacker who breached the network perimeter by gaining access through the Internet.

As members of the CSIRT team, the exercise requires describing the operational procedures to be adopted in response to the incident, with particular focus on two key phases: isolating the compromised system to stop the ongoing attack, and safely removing the system from the network. We are also required to explain the data sanitisation techniques (Clear, Purge and Destroy) to be applied to the disks before final disposal, in order to prevent recovery of sensitive information.



2 – Tools Used :

Firewall — used as the first point of intervention to block malicious traffic coming from the Internet

CSIRT Procedures — standard incident response methodologies for managing, containing and removing compromised systems

Data Sanitisation Techniques — Clear, Purge and Destroy procedures for the secure deletion of sensitive information on disks before disposal

3 - Execution

I) Isolation of System B

The purpose of isolation is to stop the ongoing attack without immediately shutting down the system, in order to preserve digital evidence.

Actions taken:

Network disconnection — System B is physically disconnected from the internal network, preventing the attacker from continuing to operate and from moving laterally to other systems (A, C, D)

Firewall block — specific rules are created on the perimeter firewall to block all inbound and outbound traffic to and from System B's IP address

Evidence preservation — before any other action, system logs, active processes and a RAM memory dump are collected, which will be useful for subsequent forensic analysis

II) Removal of System B

Once isolated, the compromised system is permanently removed from the corporate network:

Controlled shutdown — the system is safely powered off

Operating system reinstallation — the operating system is reinstalled from scratch on clean hardware or on a new virtual machine

Restore from clean backup — data is restored exclusively from a backup taken before the compromise

Verification before returning to network — before reconnecting the system to the network, a full scan is performed to verify the absence of residual malware

II) Removal of System B

Once isolated, the compromised system is permanently removed from the corporate network:

Controlled shutdown — the system is safely powered off

Operating system reinstallation — the operating system is reinstalled from scratch on clean hardware or on a new virtual machine

Restore from clean backup — data is restored exclusively from a backup taken before the compromise

Verification before returning to network — before reconnecting the system to the network, a full scan is performed to verify the absence of residual malware

4 - Sanitisation :

Before physically disposing of the disks from the compromised System B, it is mandatory to securely delete all sensitive data present. There are three levels of sanitisation, in increasing order of security:

CLEAR

This is the basic level. Data is overwritten with random values or zeros, making recovery difficult with common software tools. However, data could still be recovered using advanced forensic tools.

Practical example: overwriting the disk with the **dd** command on Linux.

Used when the disk will be reused within the same organisation.

PURGE

This is the intermediate level. Data is deleted more thoroughly using advanced techniques such as multiple overwriting or cryptographic erasure. Data recovery becomes practically impossible even with forensic tools.

Practical example: multiple overwriting with tools like **shred** on Linux, or cryptographic erasure on SSD drives.

Used when the disk will be decommissioned or transferred to third parties.

DESTROY

This is the maximum level. The disk is physically destroyed through shredding, melting or degaussing. There is no possibility of data recovery.

Used when the disk contains highly sensitive data and cannot be reused under any circumstances.

5 – Conclusions:

The work of a CSIRT team faced with a fully compromised system follows a well-defined process made up of precise phases: first the system is isolated to stop the attack and preserve evidence, then it is removed and restored in a controlled manner.

Equally important is the final disk sanitisation phase, where the choice between Clear, Purge and Destroy is not random but depends on the sensitivity of the data contained and the final destination of the hardware. In the case of System B, containing sensitive data from a compromised corporate database, the most appropriate technique would be Destroy, which guarantees the total impossibility of recovering the information.

Malware Analysis

1 - Objective

Two users at a large company report problems with their computers. As members of the CSIRT/SOC team, we are required to analyse two suspicious links using the ANY.RUN online sandbox platform, in order to identify the nature of the threats and produce a report on the ongoing attack.

2 – Tools Used

ANY.RUN — online sandbox platform that executes suspicious files and URLs in an isolated environment, recording all process behaviour

MITRE ATT&CK Framework — international standard framework for classifying attack techniques used by malware

3 - Results

CASE 1 — DNS_Changer.ps1

Verdict: Suspicious (65/100)

File analysed: DNS_Changer.ps1 — PowerShell script

Behaviour: the script is executed with the -ExecutionPolicy Bypass parameter, bypassing Windows protections. Once launched, it reads the system's Internet settings and attempts to create local accounts via PowerShell.

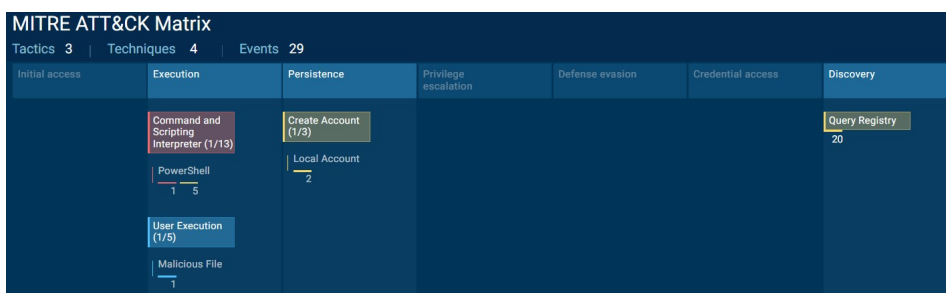
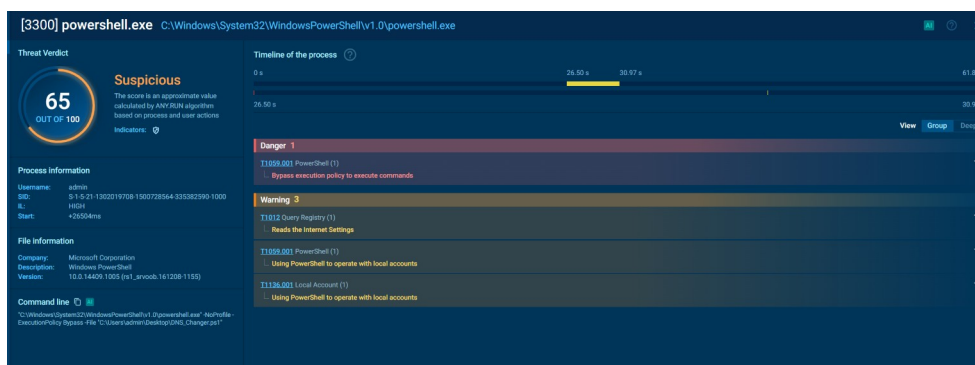
MITRE ATT&CK techniques detected:

T1059.001 — Execution via PowerShell with security policy bypass

T1012 — Reading Internet settings from the system registry

T1136.001 — Creation of local accounts via PowerShell

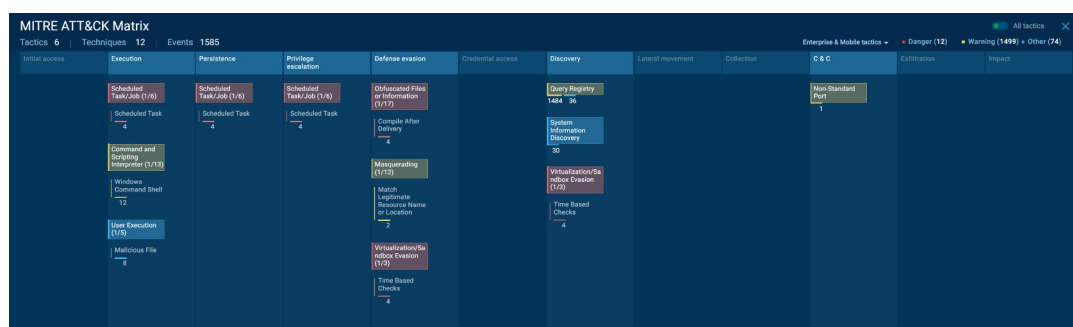
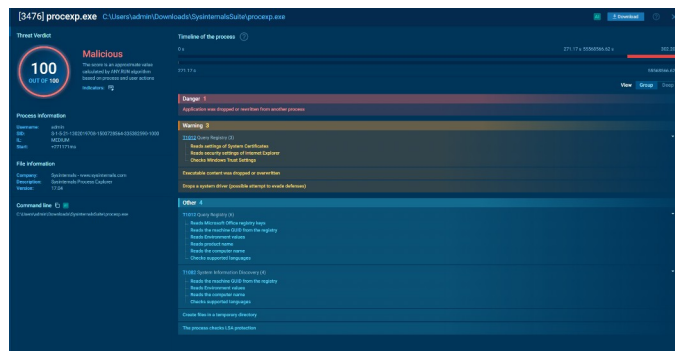
Risk: the file is likely a malware that modifies the victim's DNS settings to redirect them to fake or malicious sites



CASE 2 — procexp.exe

- **Verdict:** MALICIOUS (100/100)
- **File analysed:** procexp.exe — disguises itself as Sysinternals Process Explorer, a legitimate Microsoft tool

- **Behaviour:** the file rewrites itself autonomously, installs a system driver to hide itself, creates scheduled tasks to survive reboots and communicates with external servers on non-standard ports
-
- **MITRE ATT&CK techniques detected:**
- Execution — execution via scheduled tasks and malicious files
- Persistence — scheduled tasks to ensure survival after reboot
- Defense Evasion — masquerading, sandbox evasion, obfuscated files
- Discovery — collection of system information (GUID, computer name, language)
- C&C — communication on non-standard ports with command and control server
-
- **Risk:** advanced malware with evasion capabilities, persistence and communication with remote command infrastructure



4 - Conclusions

The analysis via the ANY.RUN sandbox allowed the identification of two distinct threats. The first case concerns a suspicious PowerShell script with DNS Changer behaviour, capable of modifying the victim's network settings. The second case is significantly more serious: a malware classified as fully malicious that disguises itself

as legitimate software, installs hidden components in the system and communicates with external servers.

In both cases, immediate isolation of the machines is recommended, removal of the identified files and a complete analysis of the systems to check for any additional malicious components not yet detected.